

JUNIO 2026

THE BRIDGE  
BOOTCAMPS



# THREAT MODEL BASADO EN MITRE ATT&CK

---



| Versión | Fecha      | Estado   | Clasificación |
|---------|------------|----------|---------------|
| 1.0     | Junio 2026 | Aprobado | Interno       |

# 01 Propósito y alcance

El presente documento recoge el modelo de amenazas de la plataforma construido sobre el framework MITRE ATT&CK, cuyo propósito es relacionar los riesgos identificados durante el análisis MAGERIT con técnicas reales documentadas y utilizadas por atacantes, permitiendo así definir controles de seguridad concretos y justificados para cada escenario contemplado.

A diferencia de un análisis de riesgos genérico, el enfoque basado en MITRE ATT&CK permite razonar sobre las amenazas desde la perspectiva del atacante: qué técnicas emplearía, sobre qué activos las aplicaría y qué indicadores dejaría en los sistemas. Este punto de vista resulta útil para priorizar los controles que se irán implementando a lo largo del proyecto, anticipar los escenarios de ataque más probables y sentar las bases sobre las que se construirán posteriormente los documentos de detección y respuesta.

Su alcance abarca los principales vectores de ataque identificados para la aplicación, incluyendo el compromiso de cuentas de usuario y administrador, la exfiltración de datos, la inyección sobre la API, la manipulación de contenido turístico y reseñas, la denegación de servicio y el robo del código fuente. Para cada amenaza se documenta la técnica ATT&CK correspondiente con su identificador, y se propone el control o conjunto de controles más adecuado para reducir su probabilidad e impacto sobre el servicio.



# 02 Amenazas identificadas y controles propuestos

A continuación se detallan las amenazas identificadas para la plataforma, las técnicas ATT&CK asociadas y los controles propuestos para cada escenario.

| Amenaza Identificada                                     | Técnica ATT&CK                           | ID ATT&CK     | Control Propuesto                                            |
|----------------------------------------------------------|------------------------------------------|---------------|--------------------------------------------------------------|
| Robo de credenciales mediante phishing                   | Phishing                                 | T1566         | MFA, verificación de correo y alertas de acceso sospechoso   |
| Credential Stuffing                                      | Valid Accounts                           | T1078         | Bloqueo de intentos, MFA y control de sesiones               |
| Acceso indebido a perfiles de otros usuarios             | Abuse of valid accounts                  | T1078         | Control de acceso basado en roles (RBAC)                     |
| Exfiltración de datos de acceso                          | Data exfiltrations                       | T1041         | Monitorización, logs y alertas SIEM                          |
| SQL Injection sobre la API                               | Exploit Public-Facing Application        | T1190         | Validación de entradas, consultas parametrizadas y SonarQube |
| Denegación de servicios sobre la aplicación              | Endpoint Denial of Service               | T1499         | Rate limiting, WAF y monitorización                          |
| Modificación maliciosa de actividades o restaurantes     | Data manipulation                        | T1565         | Control de permisos y trazabilidad de cambios                |
| Creación masiva de cuentas falsas y reseñas fraudulentas | Automated Collection / Abuse of Accounts | T1589 / T1078 | CAPCHA, limitación de registros y reglas SIEM                |
| Compromiso de una cuenta administrativa                  | Account Manipulation                     | T1098         | MFA obligatorio y monitorización de privilegios              |
| Robo del repositorio o del código fuente                 | Exfiltration to External Service         | T1567         | Control de acceso al repositorio MFA                         |

